

User Role Controlled by Request Parameter

Lab Information

Field	Value
Category	Access Control
Difficulty	Apprentice
Vulnerability	Broken Access Control

Summary

This lab demonstrates a **Broken Access Control** vulnerability where the application determines administrative privileges using a client-controlled cookie. Because the cookie value can be modified by the user, an attacker can escalate privileges by changing the role indicator and gain unauthorized access to administrative functionality.

Objective

Gain administrative access by modifying a forgeable cookie and delete the user **carlos**.

Attack Scenario

After authenticating as a normal user, the application issues a cookie that contains an `Admin` parameter. Instead of validating administrative privileges on the server, the application trusts the value supplied by the client.

By intercepting the request and changing the cookie value from `false` to `true`, an attacker can impersonate an administrator and access privileged functionality.

Steps to Reproduce

1. Log in using the provided credentials:
2. Username: `wiener`
3. Password: `peter`

4. Intercept a request using Burp Suite.

5. Locate the following cookie:

```
Admin=false
```

1. Modify the cookie value:

```
Admin=true
```

1. Forward the modified request.
2. Access the administrator panel.
3. Locate the delete action for the user **carlos**.
4. Send the request to delete the user.
5. Verify that the lab is solved.

Evidence

Original Cookie

```
Cookie: Admin=false
```

Modified Cookie

```
Cookie: Admin=true
```

Administrative Functionality

After modifying the cookie, the application granted access to the administrator panel without performing additional authorization checks.

Security Impact

An attacker can manipulate client-controlled parameters to obtain administrative privileges. This can lead to unauthorized access to sensitive functionality, user management operations, data modification, or complete application compromise.

Root Cause

The application trusted a security-critical value supplied by the client. Instead of validating user roles on the server using the authenticated session, the application relied on a forgeable cookie to determine authorization.

Remediation

- Never trust client-controlled parameters for authorization decisions.
 - Store user roles securely on the server.
 - Validate user permissions for every privileged request.
 - Sign or encrypt sensitive cookies if client-side storage is required, while still enforcing authorization on the server.
-

Pentester's Notes

When testing access control, always inspect cookies, hidden fields, URL parameters, and request bodies for values that appear to represent user roles or permissions. Parameters such as `admin`, `role`, `isAdmin`, `roleid`, or similar names are common indicators of privilege-related functionality and should be tested for manipulation.

Key Takeaways

- Client-controlled data must never determine authorization.
- Authorization decisions belong on the server, not in cookies or request parameters.
- Modifying a single parameter can reveal serious privilege escalation vulnerabilities.
- Burp Repeater is an essential tool for testing parameter manipulation and access control flaws.